EDP DIGITAL PLATFORM

Implemented Code Flow

Product, architecture, security, data and operational flows completed through P01.2

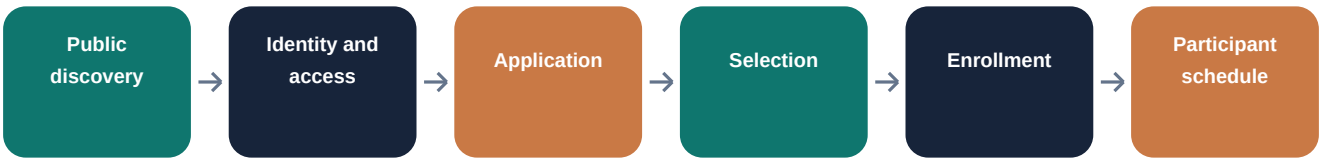
BASELINE

Repository	Branch	Commit	Prepared
viviztech/edp-digital	main	3f70069	24 September 2026

Purpose

This document explains how the code implemented to date works as connected user and system flows. It separates completed behavior from release gates and future modules. It is a technical-product handoff for review, onboarding and planning.

Current implemented journey



English/Tamil web experiences backed by FastAPI, PostgreSQL, Redis and Celery

1. Implemented capability map

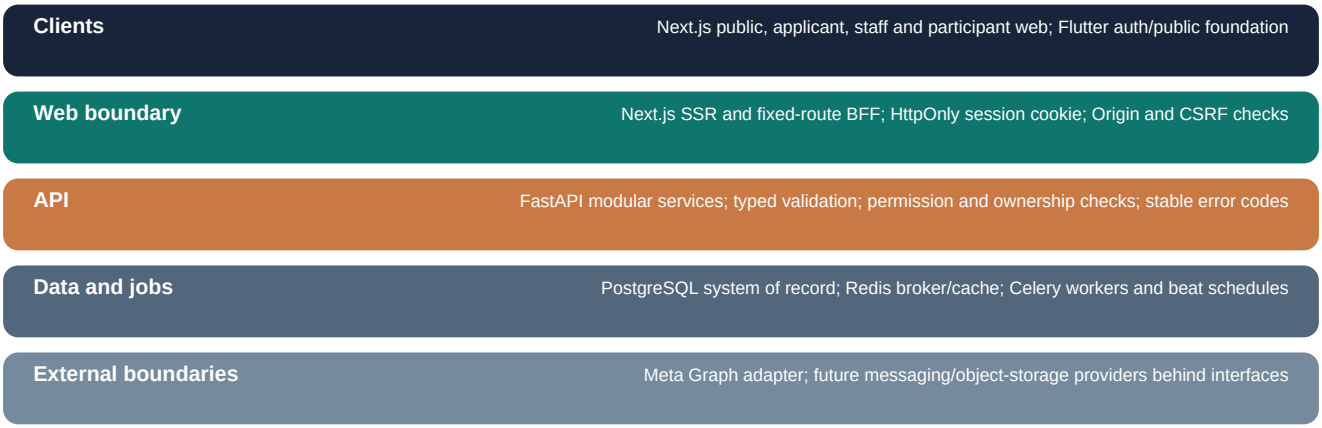
The platform is a modular monolith. Each vertical slice includes database constraints, service rules, scoped APIs, web/mobile surfaces where implemented, audit evidence and tests.

Area	Completed code flow	Primary users
Foundation	Registration, verification, login, refresh rotation, reset, session revocation, scoped RBAC and immutable audit	All users; operators
CMS and public	Localized pages, editorial content, navigation, SEO, quarantined asset metadata and privacy-safe enquiries	Visitors; Content Managers
CRM	Attributed leads, assignments, activities, tags, overdue queue, duplicate review/merge, registration link and permissioned CSV exports	CRM Executives; Managers
Meta integration	Verified webhook inbox, encrypted configuration, mapping, worker claims, recovery/replay and retention enforcement	Marketing; Operations
Communications	In-app assignment and due reminders, preferences, retention, bounded retries and audited operator replay	Staff recipients; Operations
Applications	Versioned bilingual definitions, applicant drafts, required answers, declarations/consent, immutable submission and receipt	Applicants; Program staff
Programs and selection	Programs/centers/cohorts/cycles, rubric/reviews, interviews, decisions, authorized overrides and finalization	Program staff; Reviewers
Participants	Atomic selected-to-enrolled conversion, participant projection, sessions and self-scoped schedule/timeline	Program staff; Participants

Completion statement

The end-to-end synthetic browser journey now reaches enrolled participant and scheduled program session. Learning, attendance, mentoring, funding, support, reporting and production operations remain later work.

2. Runtime and request flow



Every protected mutation carries session, scope, CSRF, request ID, optimistic version and audit context

Boundary	What the implementation enforces
Browser	No access/refresh token in JavaScript; private no-store responses; bounded JSON bodies
API	Authentication, active-account check, explicit permission, organization/owner scope and typed payload
Service	Lifecycle transition, dependency validation, row lock/version, audit and outbox in one transaction
Database	Composite scope keys, unique/check constraints, immutable evidence triggers and indexed queries
Worker	Record IDs only, bounded retries/leases, dedupe and operator-visible recovery state

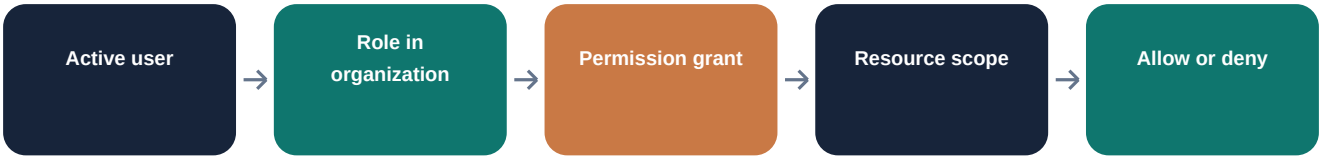
3. Identity, session and authorization flow

Person is the stable identity; User is the login account

Browser session

The browser authenticates through a server-only Next.js boundary. The API issues opaque sessions, while the browser receives an HttpOnly SameSite cookie and a session-bound CSRF token. Logout, logout-all, password reset, suspension and refresh replay revoke session families.

Authorization decision



Control	Implemented behavior
Credential storage	Argon2id password hash; hashed reset, verification, access and refresh tokens
Refresh security	One-use rotation under row lock; replay revokes the token family
Tenant isolation	Organization ID is checked in permission lookup and resource query; UUID alone grants nothing
Self access	Applicant and participant queries derive Person from the authenticated User
Audit	Consequential actions record actor, organization, resource, request ID, version and safe field names

Role examples

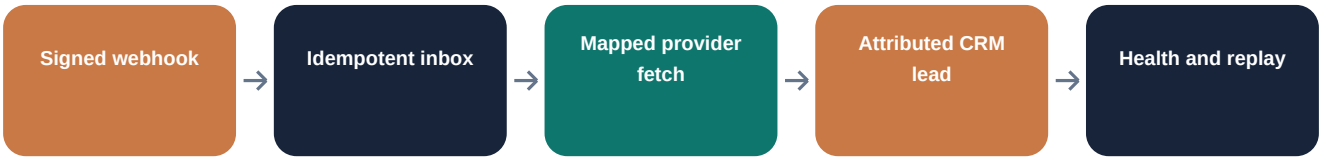
Role	Implemented access emphasis
Program Director	Policy publication, selection finalization, overrides, enrollment and schedule administration
Program Manager	Draft policy/program/selection setup, assignments, enrollment and schedule administration
Selection Committee	Only assigned review and interview scoring
Content / CRM / Marketing	Module-specific organization permissions
Participant	System access and self-only participant schedule/timeline

4. Discovery, lead and communication flow

Public content to prospect

Draft or archived CMS content is never returned by public DTOs

Meta lead ingestion



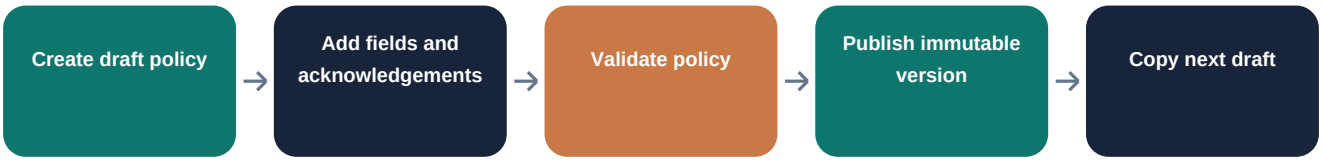
In-app communication

Retention immediately hides expired items; bounded tasks purge later

Flow	Key safeguards
CMS publication	Independent English/Tamil revision history, optimistic versions and immutable published evidence
Enquiry	Generic 202 response, privacy-notice version, bounded contact fields and dedupe hash
CRM merge	Canonical pair, mandatory reason, survivor link and preserved activity history
CSV export	Requester-only, 10,000-row bound, spreadsheet-formula escaping, 24-hour expiry
Meta	Raw-body signature verification, encrypted secrets, provider-ID dedupe, minimal retention metadata
Notifications	Recipient/scope/preference recheck, unique source/recipient, retry cap and audited replay

5. Application definition and applicant flow

Policy administration



Publishing retires the prior live version; existing applications remain pinned

Applicant journey

Submission transaction

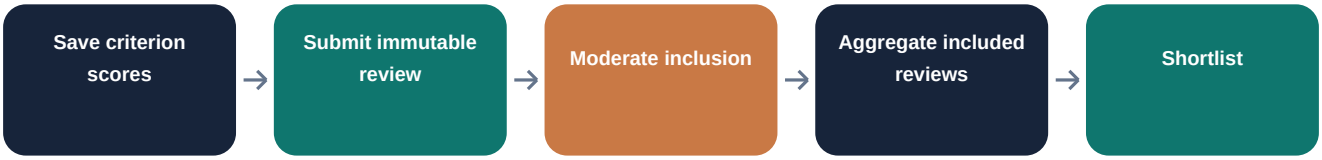
Step	Server-side result
Lock and version	Locks the application and rejects stale writes
Validate	Open cycle, pinned form, required answers, declaration and consent
Persist evidence	Immutable revision, acknowledgements with timestamps, submitted timestamp and history
Generate receipt	Unique non-PII `EDP-{year}-{sequence}` application number
Audit	Identifiers and changed-field names only; no answers or policy text

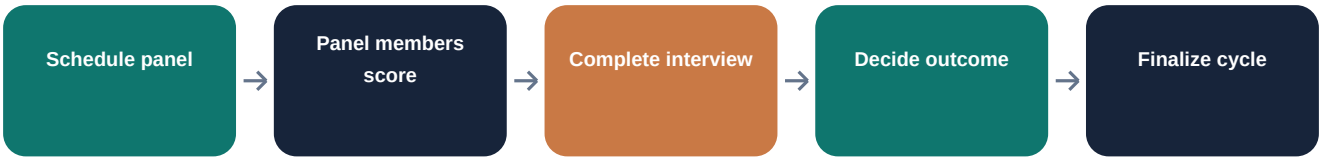
Supporting documents

A01.3 is intentionally unavailable until private object storage, malware scanning and retention policy are approved.

6. Selection management flow

Assignments pin the published rubric and move submitted applications to under review



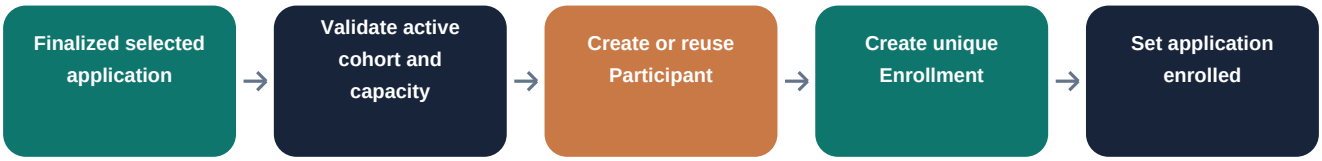


Selected, waitlisted and rejected decisions store review/interview score snapshots

Rule	Implementation
Weighted scoring	Server normalizes each criterion to its configured range and applies published weights
Conflicts	Assigned reviewer must declare clear or a reasoned conflict before scoring
Moderation	Authorized directors exclude/restore aggregate inclusion without changing submitted evidence
Interview	One panel per application; every member submits once; mean is server-calculated
Decision	Shortlist requires completed included review; terminal decisions require finalization permission
Override	Changing a terminal decision requires explicit override permission, flag and reason
Finalization	All assigned applications must be terminal and no interview may remain scheduled

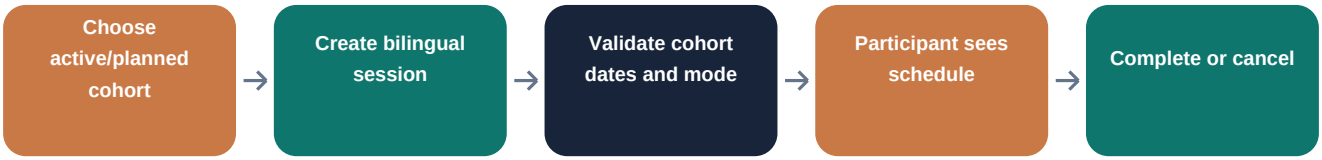
7. Enrollment, participant and schedule flow

Atomic conversion

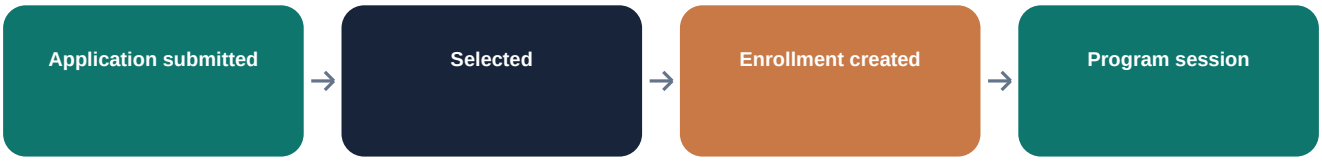


Audit, status history, Participant role binding and enrollment.created outbox commit together

Schedule delivery



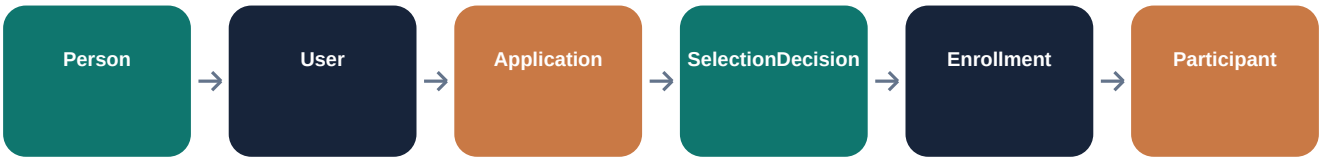
Participant timeline



Ordered projection; no reviewer scores, comments or decision reasons

Invariant	Database/service enforcement
Stable identity	Participant references Person; name, email and contact data are not copied
One conversion	Enrollment.application_id is unique
No duplicate cohort seat	Enrollment is unique by participant and cohort
Scope	Composite foreign keys bind participant, application, program and cohort to one organization
Capacity	Active enrollment count is checked under locked conversion dependencies
Self visibility	Timeline query matches Participant.person_id to authenticated User.person_id

8. Core data lineage



Person is the stable identity root; business stages reference it instead of duplicating it

Aggregate	Key relationships and evidence
Identity	Person 1:1 User; User -> scoped roles -> permissions; User -> refresh sessions/tokens
Applications	Application -> immutable revisions/answers/acknowledgements/status history; cycle -> form/program/cohort
Selection	SelectionCycle -> rubric/criteria -> review assignments/scores; Application -> interview/panel -> append-only decisions
Programs	Program -> Cohort -> ProgramSession; TrainingCenter -> Cohort; ApplicationCycle binds program/cohort/form
Participants	Person -> Participant per organization; Participant -> Enrollment; Enrollment -> selected Application and Cohort
Operations	Domain change -> AuditLog; asynchronous change -> outbox/inbox/notification state

Database protection model

? Composite foreign keys reject cross-organization and cross-program links even if application code is bypassed.

? Unique constraints prevent duplicate submissions, assignments, scores, provider events, enrollments and reminders.

? Check constraints encode lifecycle values, timestamps, ranges, completion evidence and mode/location consistency.

? PostgreSQL triggers freeze published policy, submitted applications, scores, interviews, decisions, histories and outbox identity evidence.

? Editable workflows use optimistic versions; consequential service commands use row locks and one transaction.

9. User surfaces and API boundaries

Surface	Implemented routes/workspaces	Boundary
Public web	Localized home, CMS pages, editorial lists/details, sitemap and robots	Published content only; canonical and language metadata
Account	Register, verify, sign in, reset, devices and sign-out	Opaque HttpOnly browser session
Applicant	`/[locale]/applications`	Owner-scoped drafts, submission receipt and status history
Staff admin	CMS, CRM, Meta, notifications, application definitions, programs and selection	Permission-aware UI plus fixed route-specific BFF allowlists
Participant	`/[locale]/participant`	Self-scoped enrollment journey and cohort sessions
Flutter	Authentication and public CMS/editorial foundation	Native-device completion remains deferred
Swagger	`/docs` in local/test	Generated OpenAPI; disabled in production environment mode

Representative command APIs

Domain	Command style
Application	Create/resume draft, save revision, submit with exact version and acknowledgements
Selection	Explicit publish, conflict, submit review, moderate, interview score/complete, decision and finalize commands
Programs	Explicit resource state commands; enrollment conversion; participant state; session create/state
CRM/Meta/Notifications	Versioned lifecycle commands, assignment/merge/replay reasons and bounded collection reads

Contract rule

FastAPI is the contract source. OpenAPI is exported to `packages/api-contracts/openapi.json`, then TypeScript definitions are generated for Next.js. Clients do not submit calculated scores, participant identity links or enrollment scope.

10. Security and Definition of Done evidence

Gate	Latest evidence at commit 3f70069
Backend workflow	81 PostgreSQL-backed tests passed
Focused selection/program	4 end-to-end service/database tests passed, including negative authorization and ownership
Web	30 Vitest tests, ESLint and strict TypeScript passed
Build	Next.js production build passed, including participant route
Database	P01.2 populated downgrade, re-upgrade and Alembic drift check passed
Static checks	Focused Ruff and strict MyPy passed for selection/program modules
Browser	Authenticated Chrome passed identity -> application -> selection -> enrollment -> session -> participant timeline
Browser quality	Responsive layout assertions passed; no JavaScript errors
Contracts/docs	OpenAPI and TypeScript regenerated; ERD, security, privacy, API, testing and user guides updated

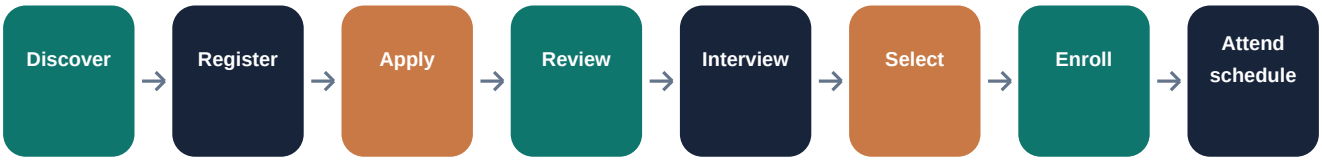
Cross-cutting controls

Risk	Implemented mitigation
Broken object access	Permission plus tenant/owner query, composite database scope, negative tests
Evidence tampering	Immutable database triggers and append-only history
Duplicate actions	Unique constraints, idempotent commands and provider event keys
Browser token theft/CSRF	HttpOnly session, BFF-held credentials, Origin and double-submit CSRF
Sensitive telemetry	Allowlisted audit fields, IDs in tasks/outbox, generic external errors
Job loss/retry	PostgreSQL inbox/outbox concepts, leases, bounded retries and operator replay

11. Delivery chronology and current boundary

Milestone	Implemented result
Foundation	Repository architecture, FastAPI/Next.js/Flutter/PostgreSQL/Redis/Celery bootstrap, auth/RBAC/audit
Milestone 2	Localized CMS/public publishing, editorial, asset quarantine, enquiries, SEO and CRM foundation
Milestone 3	CRM operations, Meta ingestion/recovery/retention, in-app notifications/retries and UI system pilot
Milestone 4	Application definitions/drafts/submission, program foundation and complete selection workflow
Milestone 5 / P01.2	Enrollment conversion, participant projection, program sessions and participant timeline

Implemented end-to-end business path



Explicitly outside completed code

Pending area	Reason / next dependency
A01.3 supporting documents	Private object storage, malware scanning and approved retention
Center/cohort staff bindings	Needed before Training Center Coordinators receive mutation permissions
LMS and assessments	Next participant capability based on Enrollment
Attendance and QR	Build against ProgramSession and Enrollment
Mentoring, funding, support, impact	Later P0 vertical slices
Production release	Remote CI for latest commit, live-provider approvals, monitoring/restore/UAT and native-device gates

Document status

This PDF describes completed repository behavior at commit 3f70069. It is not a production approval, compliance certification or claim that deferred native/provider/operations gates have passed.

Source references: `EDP_CODEX_MASTER_INPUT.md`, `docs/sdlc/*-report.md`, `docs/architecture/system-architecture.md`, `docs/database/erd.md`, `docs/security/security-model.md`, generated OpenAPI, tests and browser acceptance runner.